

FIXPROOF

Evidence that changed the review

A frozen primary study, later supplemental evidence, and bounded human decisions

Python orchestrator | JavaScript/Express fixtures | XSS, SQLi, traversal

1. Research question and bounded scope

What can this controlled benchmark establish - and what can it not establish?

RESEARCH QUESTION

Can separately recorded static, runtime, behavioral, policy, and human evidence support a defensible patch decision?

CLAIM BOUNDARY

Workflow evidence - not a production success-rate estimate.

Three fixtures

Reflected XSS
SQL injection
Path traversal

Fixed generation

gpt-5.2
Prompt v1.0
No model tools

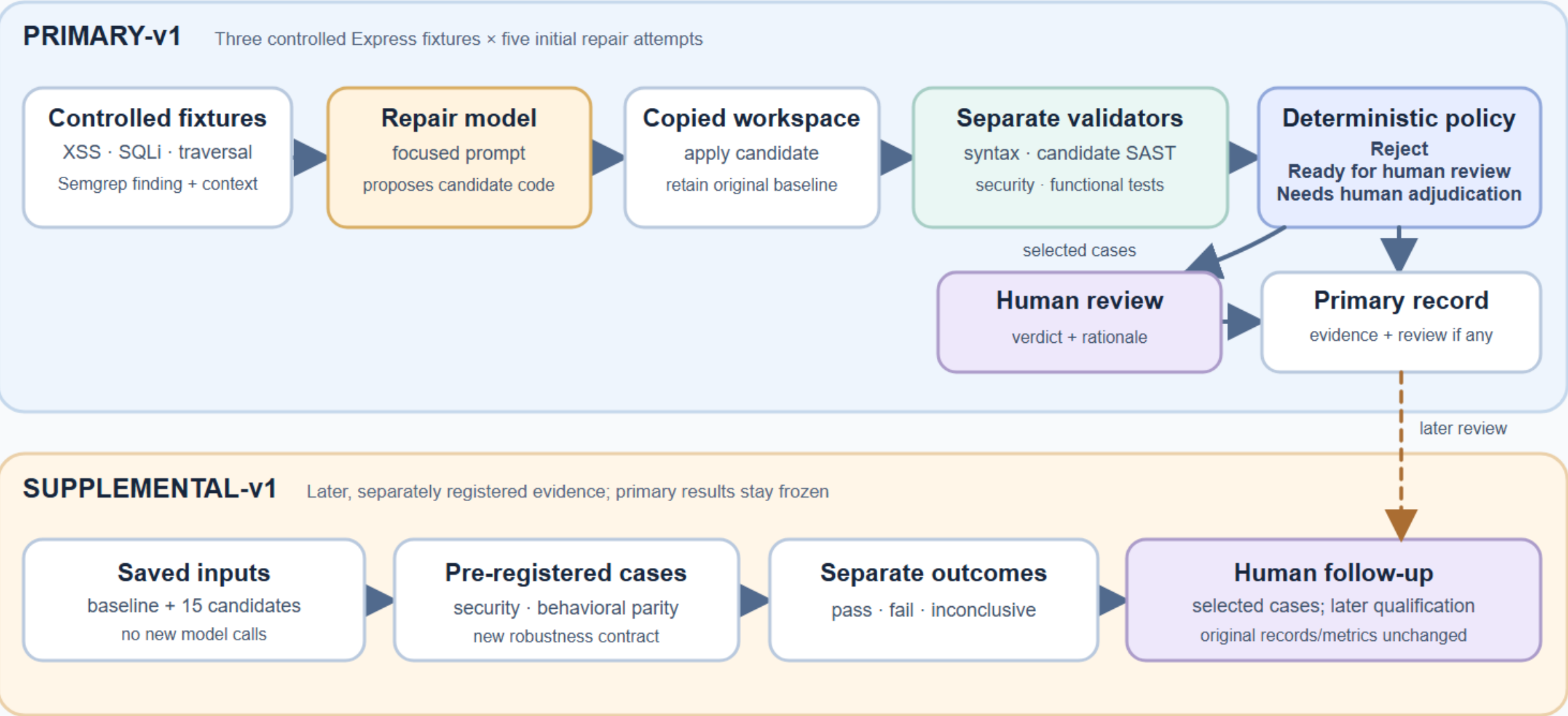
Separate authority

Model proposes
Validators measure
Human decides

One fixture per CWE and repeated repairs support descriptive evidence, not population-level generalization.

FIXPROOF | Evidence-first repair workflow

Python orchestrates: the model proposes code; separate checks, policy, and reviewers assess it.



No automatic approval or deployment. Copied workspaces protect study inputs; they are not security sandboxes.

2. Frozen primary-v1 study

Five initial calls per CWE; complete all 15; do not stop early based on outcomes

15
scheduled model calls

5 / 15
target SAST resolved

15 / 15
primary security suites

10 / 15
SAST/runtime disagreements

Primary case	Calls	SAST resolved	Security	Functional	Automated state
Reflected XSS	5	0 / 5	5 / 5	5 / 5	Needs adjudication
SQL injection	5	5 / 5	5 / 5	5 / 5	Ready for review
Path traversal	5	0 / 5	5 / 5	5 / 5	Needs adjudication
Total	15	5 / 15	15 / 15	15 / 15	5 ready 10 adjudicate

0 / 5 resolved means the target scanner finding persisted - not that zero candidates blocked the tested attacks.

3. Supplemental-v1: later, predefined evidence

Same saved candidates | baseline gates first | no new model calls | primary metrics stay frozen



Category	Observations	Pass	Fail	Inconclusive	Interpretation
Security	60	55	0	5	Symlinkunavailable
Behavioral parity	45	40	5	0	Observable changes
Robustness	35	25	10	0	New input contracts
Total	140	120	15	5	Mixed categories

Denominators: 12 security x 5 = 60 | 9 parity x 5 = 45 | 7 robustness x 5 = 35

Do not pool these into one "security success rate."

4. Evidence demo: follow one candidate chain

Use the public reference first; open a raw saved artifact only if time allows

- 1 Frozen plan** trial-plan.json -> 5 per CWE, 15 total, complete all
- 2 Primary result** primary dashboard/report -> persistent SAST + passing runtime
- 3 Candidate patches** XSS 03 String(value) vs XSS 04 String(value ?? "")
- 4 Registered result** XSS-P01 -> Hello undefined (pass) vs Hello [blank] (fail)
- 5 Human record** XSS 04 -> FOLLOW_UP_REJECT_CANDIDATE

OPEN BEFORE RECORDING

```
fixproof.netlify.app  
  filter: Reflected XSS  
  open: XSS 04
```

Local evidence backup:
trial-plan.json

```
XSS attempt-03/  
candidate.patch  
result.json
```

```
XSS attempt-04/  
candidate.patch  
result.json  
follow-up result.json
```

The public site is a sanitized view of saved evidence; it does not replay historical model calls or tests.

5. XSS 03 versus XSS 04

Both passed the registered attacks; one changed missing-input behavior

XSS 03

PATCH

String(value)

SAVED XSS-P01 OBSERVATION

```
"body": "<h1>Hello undefined</h1>"  
"status": "pass"
```

Supplement: 9 pass | 0 fail | parity 5/5

XSS 04

PATCH

String(value ?? "")

SAVED XSS-P01 OBSERVATION

```
"body": "<h1>Hello </h1>"  
"status": "fail"
```

Supplement: 8 pass | 1 fail | parity 4/5

Both security: 3/3 pass. XSS 04 follow-up: reject for parity - not because XSS remained exploitable.

6. Human judgment and next steps

Later records qualify the evidence; they never overwrite primary-v1

10 original reviews

7 accept | 3 request more testing

14 later records

5 reject | 5 bounded accept | 4 request

0 overwritten

primary records and metrics stay frozen

LIMITS TO SAY OUT LOUD

- One application per CWE
- 15 calls are not 15 unique patches; SQLi has one source
- PATH-S06 remains inconclusive on Windows
- SQLi target comparison used a labeled controlled rule
- No production-readiness or broad success-rate claim

NEXT COURSE MILESTONES

- Planned early Report 3 submission: October 1
- Official Report 3 deadline: October 4, 11:59 p.m.
- Post Video III: October 6
- Peer Feedback Report 3: October 11, 11:59 p.m.
- Continue related work and clean-package rehearsal

Student reference: fixproof.netlify.app | Feedback: prioritize a second reviewer or a symlink-capable rerun?

BACKUP | If asked about SQLi or traversal

Skip during the main recording unless the course format allows extra detail

SQLi01-05

Primary target SAST: 5/5 resolved

Primary security + functional: 5/5 candidates pass

Supplement per candidate:

- Security 3/3
- Parity 2/2
- Robustness 2/3

SQL-R01: repeated usernames returned HTTP 200 [] instead of registered HTTP 400.

Human result: bounded accept; failure remains recorded.

Traversal02-05

Primary target SAST: 0/5 resolved

Primary security + functional: 5/5 candidates pass

Supplement:

- Five executable security cases pass per candidate
- PATH-S06 symlink case remains inconclusive
- Traversal 03 fails R01-R03
- Traversal 05 fails R03

Human result: request more testing; no symlink-safety claim.

Full matrices and rationales: Video-III-15-candidate-evidence-appendix.pdf